

 Cập nhật tháng 8 năm 2024

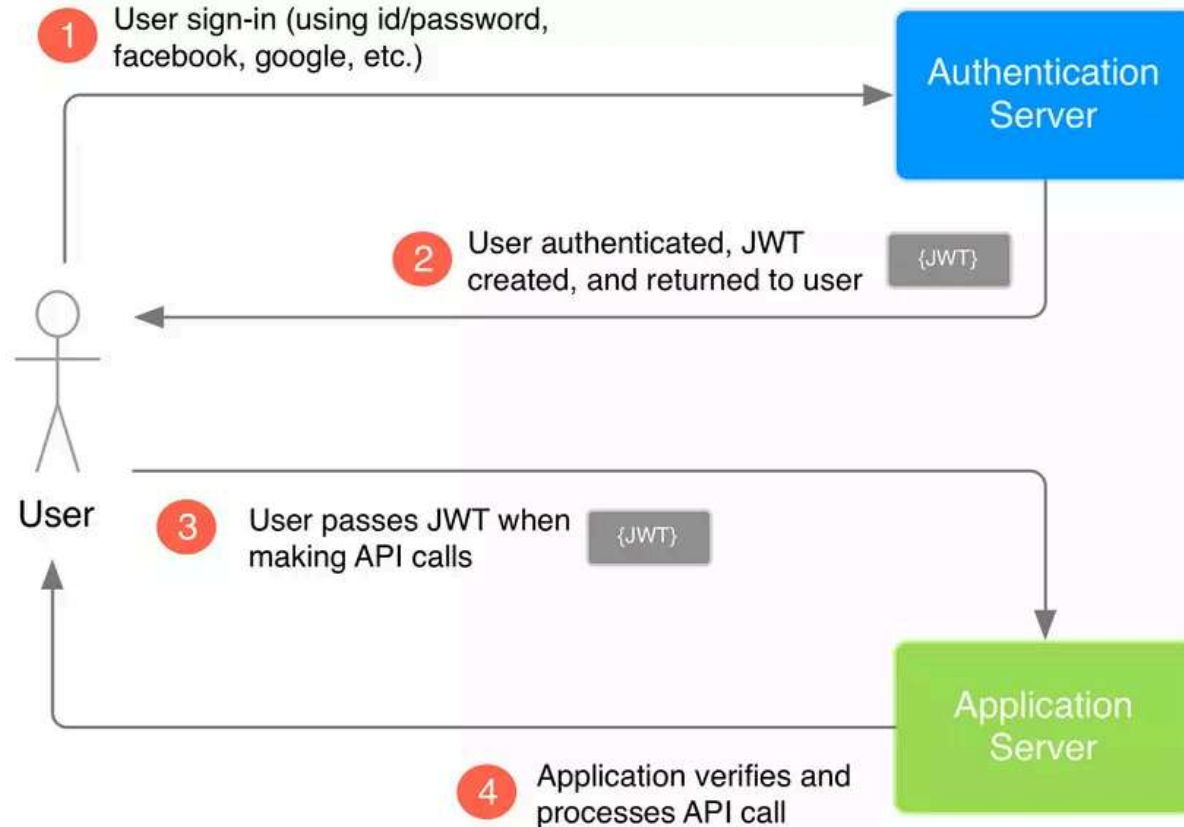
[Bài đọc] Quy trình hoạt động của JWT

1. JWT hoạt động như thế nào?

- **Xác thực** : Khi người dùng đăng nhập vào web ứng dụng, máy chủ sẽ tạo JWT chứa thông tin về người dùng, giống như tên người dùng và vai trò của họ đối với ứng dụng. Sau đó, máy chủ sẽ gửi JWT đến máy khách, nơi lưu trữ có thể là bộ nhớ cục bộ hoặc cookie.
- **Ủy quyền** : Khi khách hàng đưa ra yêu cầu tới máy chủ về tài nguyên được bảo vệ, nó sẽ gửi JWT cùng với yêu cầu. Sau đó, máy chủ xác minh chữ ký của JWT để đảm bảo chữ ký không giả mạo và kiểm tra thông tin trong quá trình tải xuống để xác định xem người dùng có các quyền cần thiết để truy cập tài nguyên hay không.

Nếu JWT hợp lệ và người dùng cần có các quyền thì máy chủ sẽ phản hồi các tài nguyên được yêu cầu. Nếu JWT không hợp lệ hoặc người dùng không có các quyền cần thiết thì máy chủ sẽ phản hồi bằng một lỗi.

2. Quy trình hoạt động chi tiết của JWT



JWT (JSON Web Token) hoạt động dựa trên việc tạo ra một chuỗi mã hóa chứa thông tin xác thực của người dùng sau khi đăng nhập thành công. Client sẽ lưu trữ token này và sử dụng nó để gửi kèm trong các request tiếp theo, thay vì phải gửi lại thông tin đăng nhập. Server sẽ kiểm tra token này để xác thực người dùng và cấp quyền truy cập tài nguyên.

Đăng nhập và xác thực:

- Người dùng gửi thông tin đăng nhập (ví dụ: username và password) lên server.
- Server xác thực thông tin người dùng.
- Nếu xác thực thành công, server sẽ tạo một JWT và ký nó bằng một private key.
- JWT bao gồm các thông tin như:
 - **Header:** Chứa thông tin về thuật toán hash được sử dụng.
 - **Payload:** Chứa các thông tin về người dùng (ví dụ: user ID, role, etc.).
 - **Signature:** Được tạo bằng cách sử dụng header, payload và private key.
- Server trả về JWT cho client.

Sử dụng JWT:

- Client lưu trữ JWT (thường trong **localStorage**, **sessionStorage** hoặc **cookies**).
- Khi client muốn truy cập một tài nguyên được bảo vệ, nó sẽ gửi JWT kèm theo request (thường trong header Authorization với prefix Bearer).
- Ví dụ: Authorization: Bearer <JWT>

Xác thực và ủy quyền:

- Server nhận request và JWT.
- Server sử dụng public key (được tạo ra từ private key) để giải mã JWT và xác minh chữ ký.
- Nếu chữ ký hợp lệ, server xác định rằng JWT chưa bị thay đổi và thông tin trong JWT là chính xác.
- Server có thể sử dụng thông tin trong payload để xác thực người dùng và cấp quyền truy cập tài nguyên.
- Nếu JWT không hợp lệ, server sẽ từ chối request.

Danh sách các bài học

